

Seguretat lògica

Seguretat lògica

La **seguretat lògica** complementa els elements de la seguretat passiva. El seu objectiu principal és el control d'accés als sistemes informàtics, que implica verificar la identitat d'una persona abans de concedir-li permís per accedir a llocs, dades o programes concrets.

Aquestes mesures formen part integral de la cadena de seguretat.
Per a la concreció dels drets d'accés d'una persona al sistema s'utilitzen estructures lògiques com les matrius de control d'accés i les llistes de control d'accés (ACL).

Abans d'aplicar qualsevol permís, cal autenticar l'usuari. El mètode d'autenticació més habitual és mitjançant contrasenyes, la fortalesa de les quals depèn de l'aplicació d'una bona política de contrasenyes.



Elements Bàsics de Control d'Accés

El Control d'accés es una mesura fonamental de la seguretat informàtica per a protegir la informació, determinant qui o què pot accedir als recursos del sistema i amb quin tipus de permís.



Què son les ACL?

La llista de control d'accés (ACL o access control list en anglès) és un concepte de seguretat informàtica utilitzat per a fer complir la separació de privilegis. Això significa donar o no uns privilegis a un objecte determinat que està realitzant una consulta.

En aquet cas quan ens referim a un objecte ens referim a un recurs, com pot ser un arxiu, una base de dades, una conexio a internet etc.

Autenticació i Autorització

Autenticació

És el pas inicial: la verificació de la identitat d'una entitat (usuari, programa, etc.) que vol accedir al sistema.

- Funció: Determina si l'usuari pot entrar al sistema o ha de quedar-se fora.

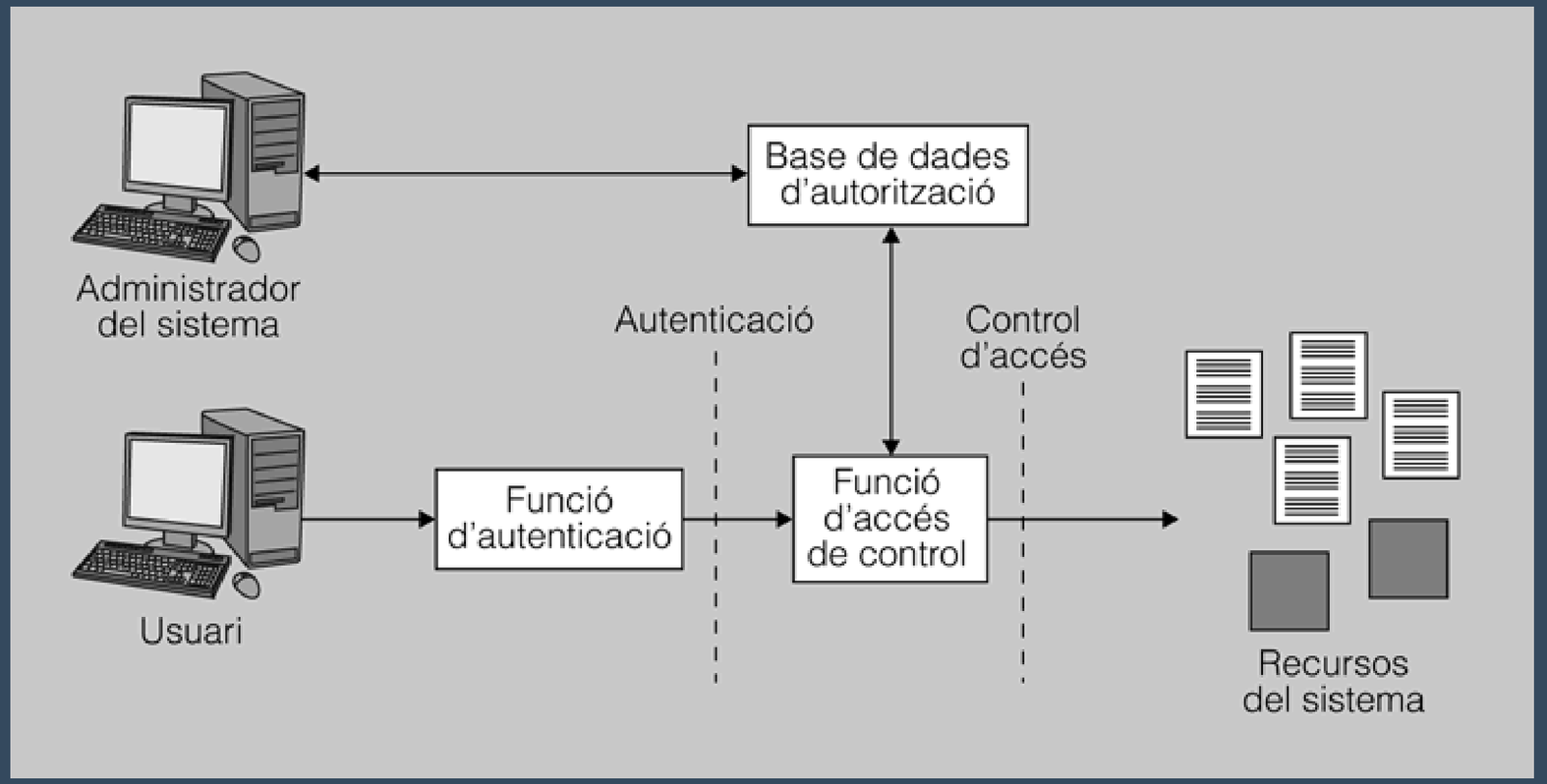
Autorització i Control d'Accés

Un cop autenticat, l'usuari passa al procés d'Autorització, que és implementat pel Control d'Accés.

- Autorització: És la concessió d'un dret o permís a l'entitat per accedir a un recurs específic del sistema.
- Control d'Accés: Consulta la base de dades d'autorització (mantinguda per l'administrador) per determinar quin tipus d'accés té l'usuari al recurs sol·licitat.

En resum, l'**Autenticació** permet l'entrada al sistema, i el Control d'Accés basat en l'**Autorització** determina l'accés permès a recursos interns. Aquesta funció de control d'accés pot ser duta a terme per un o diversos components del sistema.

L



Esquema d'autenticacio

Objectes, subjectes i drets d’accés

- **Objecte:** és un recurs que té l’accés controlat. És una entitat per emmagatzemar i/o rebre informació. Exemple: fitxers, directoris i programes.

- **Subjecte:** És una entitat capaç d’accedir a objectes. Quan un usuari o aplicació vol accedir a un objecte, en realitat ho fa per mitjà d’un procés que representa l’usuari o aplicació concrets. Tot i així, és habitual parlar d’usuaris com a subjectes.



Clases de subjectes

Normalment es defineixien tres classes de subjectes, amb diferents drets d'accés per a cada classe:

- **Propietari**: aquest podria ser el creador d'un recurs, com un fitxer o directori.

- **Grup**: a més dels privilegis assignats a un propietari, un grup concret d'usuaris també pot tenir privilegis d'accés a determinats recursos. En molts casos, un usuari pot pertànyer a diversos grups.

- **Altres**: un nombre més petit d'accessos es concedeix a usuaris que han entrat al sistema, però que no pertanyen a la categoria de propietari o de grup per a un recurs determinat.

Un **dret d'accés** indica de quina manera un subjecte pot accedir a un objecte.

Clases de drets d'accés

Els drets d'accés poden incloure les accions següents:

- **Lectura**: un usuari pot visualitzar la informació d'un recurs donat (fitxer, directori, registre...). L'accés de lectura permet copiar o imprimir recursos.
- **Escriptura**: un usuari pot afegir, modificar o eliminar dades d'un recurs donat.
- **Execució**: un usuari pot executar programes específics.
- **Esborrament**: un usuari pot eliminar certs recursos com fitxers o registres.
- **Creació**: un usuari pot crear nous fitxers, registres o directoris.



Política de Control d'Accés

Una **política de control d'accés** és el conjunt de normes, plasmades a la base de dades d'autorització, que defineixen **qui o que** pot accedir als recursos, **quin tipus d'accés** se li permet i en **quines circumstàncies.**

Control d'Accés Discrecional (DAC)

El **Control d'Accés Discrecional (DAC)** és una política de control d'accés que es basa en la identitat del sol·licitant i en unes normes d'accés (autoritzacions) que determinen les seves accions permeses.

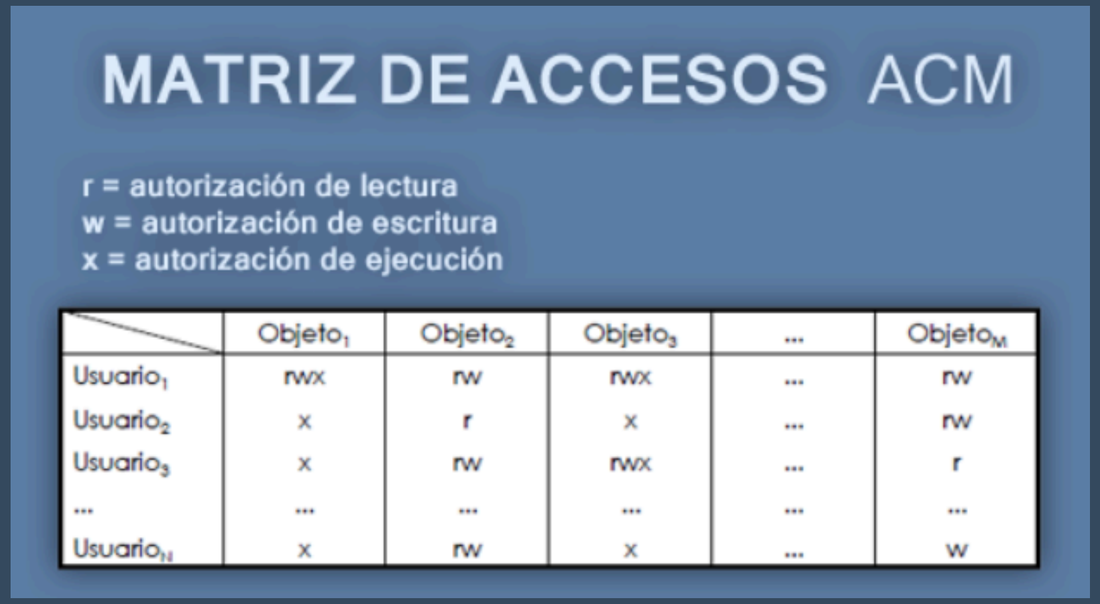
- El terme **"discrecional"** implica que un subjecte que ja té drets d'accés sobre un recurs pot, a la seva discreció, **concedir (o delegar) aquests mateixos drets d'accés a un altre subjecte.**

Per **exemple** l'acció de compartir un document que podem tenir al nostre drive i especificar els permisos de lectura/edició

Matriu de Control d'Accés

La Matriu de Control d'Accés és una implementació freqüent del DAC.

- És una taula on:
  - Les files representen els subjectes (usuaris, programes, etc.).
  - Les columnes representen els objectes (recursos, fitxers, etc.).
  - La intersecció d'una fila i una columna (la cel·la) conté els drets d'accés específics que té el subjecte sobre aquell objecte.



	$Objeto_1$	$Objeto_2$	$Objeto_3$	...	$Objeto_M$
$Usuario_1$	rwx	rw	rwx	...	rw
$Usuario_2$	x	r	x	...	rw
$Usuario_3$	x	rw	rwx	...	r
...	...	...	...	...	...
$Usuario_N$	x	rw	x	...	w